

1/18

□

File No: EXP202204816

RESOLUTION OF TERMINATION OF THE PROCEDURE DUE TO VOLUNTARY PAYMENT

From the procedure initiated by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: On June 13, 2023, the Director of the Spanish Agency for Data Protection decided to initiate sanctioning proceedings against INSTITUT MARQUÉS OBSTETRICIA I GINECOLOGIA, S.L.P. (hereinafter, the respondent), through the Agreement that is transcribed:

<<

File No: EXP202204816

IMI Reference: A56ID 406200 Case Register 434041

AGREEMENT TO INITIATE SANCTIONING PROCEDURE

From the actions carried out by the Spanish Agency for Data Protection and based on the following

FACTS

FIRST: On April 18, 2022, the General Subdirectorate of Data Inspection (SGID) received for its assessment a notification of a personal data security breach sent by INSTITUT MARQUÉS OBSTETRICIA I GINECOLOGIA, S.L.P. with NIF B62187323 (hereinafter, INSTITUTO MARQUÉS or “the notifying entity”), which was received by this Agency on December 24, 2021, in which it informs the Spanish Agency for Data Protection of the following:

Breach of availability due to cyberattack with possible consequences for those affected. There are indications that data extracted from the breach have been used to send emails to the affected individuals.

Date of detection of the breach: December 21, 2021.

They indicate that they communicated the breach to the affected individuals on March 29, 2022, following the knowledge, on March 25, 2022, that the confidentiality of the data had indeed been compromised. They became aware of this because the notifying entity received an email from the account ***URL.1 that contained their own data extracted from the information systems of the notifying entity.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

2/18

There are affected individuals in other countries: France, Ireland, Italy, Romania, and the United Kingdom.

Number of affected individuals according to notification: 400 users, patients, and employees.

Type of data according to notification: Identity data, image, contact data, economic and payment method data, and health and genetic data.

SECOND: Through the “Internal Market Information System” (hereinafter IMI System), regulated by Regulation (EU) No. 1024/2012 of the European Parliament and of the Council, of October 25, 2012 (IMI Regulation), whose objective is to promote cross-border administrative cooperation, mutual assistance among Member States, and the exchange of information, on June 6, 2022, this Agency declared itself the lead authority in this matter. The transfer of this issue is carried out in accordance with the provisions of Article 56 of Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016, regarding the Protection of Natural Persons concerning the Processing of Personal Data and the Free Movement of such Data (hereinafter, GDPR), taking into account its cross-border nature and that this Agency is competent to act as the lead supervisory authority, given that INSTITUTO MARQUÉS has its registered office and establishment in Spain.

The data processing carried out affects individuals in several Member States. According to the information incorporated into the IMI System, in accordance with the provisions of Article 60 of the

GDPR, the authority of Italy acts as the “concerned supervisory authority,” under Article 4.22 of the GDPR, since the individuals residing in the territory of this supervisory authority are substantially affected or are likely to be substantially affected by the processing subject to this procedure.

THIRD: The General Subdirectorate of Data Inspection proceeded to carry out preliminary investigative actions to clarify the facts in question, by virtue of the functions assigned to the supervisory authorities in Article 57.1 and the powers granted in Article 58.1 of the GDPR, and in accordance with the provisions of Title VII, Chapter I, Section Two, of Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter, LOPDGDD), being aware of the following aspects:

Regarding the company

The notifying entity is a limited liability company of Spanish nationality. According to the data available in AXESOR, it is a parent company with 115 employees and a sales volume of 9,684,025 euros. No previous files related to breaches by this entity have been found in the information systems of this Agency.

Information and documentation have been requested from the notifying entity, and from the response received on June 27, 2022, along with the information provided in the breach notifications made on December 24, 2021, February 15, 2022, and March 30, 2022, the following is inferred:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/18

Regarding the chronology of the events. Actions taken to minimize adverse effects and measures adopted for final resolution

(...).

(...).

(...).

(...).

(...).

(...).

(...).

(...).

(...):

(...)

“(...).”

(...):

(...)

(...).

(...).

(...).

(...).

(...).

(...):

(...)

(...).

(...).

(...).

(...).

(...)

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

Regarding the data processing agreement

(...):

- (...).
- "(...)."
- (...).
- "(...)."

Regarding the security measures implemented

(...):

- (...)
- (...)
- (...).
- (...)
- (...).

FOURTH: On March 21, 2023, the Director of the AEPD adopted a draft decision to initiate sanctioning proceedings. Following the process established in Article 60 of the GDPR, on March 31, 2023, this draft decision was transmitted via the IMI system, and the interested authorities were informed that they had four weeks from that moment to submit relevant and justified objections. The processing period of the present sanctioning procedure was automatically suspended during these four weeks, in accordance with the provisions of Article 64.4 of the LOPDGDD.

Within the stipulated timeframe, the interested supervisory authorities did not submit relevant and justified objections, therefore it is considered that all authorities agree with this draft decision and are bound by it, in accordance with the provisions of paragraph 6 of Article 60 of the GDPR. This draft decision, which was notified to INSTITUTO MARQUÉS in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (LPACAP), was received on April 22, 2023, as evidenced by the acknowledgment of receipt in the file.

LEGAL GROUNDS

I

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

Competence and applicable regulations

In accordance with the provisions of Articles 58.2 and 60 of Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, regarding the protection of natural persons with regard to the processing of personal data and the free movement of such data (GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 and 68.2 of the LOPDGDD, the Director of the Spanish Data Protection Agency is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Data Protection Agency will be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued for its development, and, as long as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Preliminary issues

In the present case, in accordance with the provisions of Articles 4.1 and 4.2 of the GDPR, there is evidence of the processing of personal data, given that INSTITUTO MARQUÉS collects and retains, among others, the following personal data of natural persons: identity data, image, contact data, economic data and payment methods, and health and genetic data, among other treatments. INSTITUTO MARQUÉS carries out this activity in its capacity as data controller, as it determines the purposes and means of such activity, by virtue of Article 4.7 of the GDPR. Furthermore, this is a

cross-border processing, given that INSTITUTO MARQUÉS is established in Spain, although it provides services to other countries in the European Union.

The GDPR provides, in its Article 56.1, for cases of cross-border processing, as foreseen in its Article 4.23), regarding the competence of the main supervisory authority, that, without prejudice to the provisions of Article 55, the supervisory authority of the main establishment or the only establishment of the controller or the processor shall be competent to act as the main supervisory authority for the cross-border processing carried out by such controller or processor in accordance with the procedure established in Article 60. In the case examined, as stated, INSTITUTO MARQUÉS has its establishment in Spain, therefore the Spanish Data Protection Agency is competent to act as the main supervisory authority.

For its part, Article 4, paragraph 12 of the GDPR broadly defines “personal data security breaches” (hereinafter security breach) as “all breaches of security that lead to the accidental or unlawful destruction, loss, alteration of personal data transmitted, stored, or otherwise processed, or unauthorized communication or access to such data.”

In the present case, there is evidence of a personal data security breach under the circumstances indicated above, categorized as a confidentiality breach and

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/18

of availability, having improperly accessed the personal data of at least 400 users, and the personal data of these users has been inaccessible since December 21, 2021.

Within the principles of processing provided for in Article 5 of the GDPR, the integrity and confidentiality of personal data is guaranteed in section 1.f) of Article 5 of the GDPR. In turn, the security of personal data is regulated in Articles 32, 33, and 34 of the GDPR, which govern the security of processing, the notification of a personal data security breach to the supervisory authority, as well as the communication to the data subject, respectively.

III

Duty of confidentiality

Article 5.1.f) “Principles relating to processing” of the GDPR states:

“1. Personal data shall be:

(...)

f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, by means of the application of appropriate technical or organizational measures (‘integrity and confidentiality’).”

In this case, it is noted that the personal data of more than 400 users, contained in the INSTITUTO MARQUÉS database, was accessed by a third party as a result of the security breach suffered.

In accordance with the evidence available in this initiation agreement for sanctioning procedure, and without prejudice to the outcome of the investigation, it is considered that the known facts could constitute an infringement attributable to INSTITUTO MARQUÉS, for violation of Article 5.1.f) of the GDPR.

IV

Classification and qualification of the infringement of Article 5.1.f) of the GDPR

If confirmed, the aforementioned infringement of Article 5.1.f) of the GDPR could constitute the commission of the infringements classified in Article 83.5 of the GDPR, which under the heading “General conditions for the imposition of administrative fines” provides:

“Violations of the following provisions shall be subject to administrative fines of up to 20,000,000 EUR or, in the case of an undertaking, an amount equivalent to 4% of the total annual global turnover of the preceding financial year, whichever is higher:

a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9;

(...)"

In this regard, the LOPDGDD, in its Article 71 "Infringements" establishes that:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/18

"Acts and conduct referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those contrary to this organic law, constitute infringements."

For the purposes of the limitation period, Article 72 "Infringements considered very serious" of the LOPDGDD indicates:

"1. In accordance with what is established in Article 83.5 of Regulation (EU) 2016/679, the following infringements are considered very serious and shall be subject to a limitation period of three years, which involve a substantial violation of the articles mentioned therein and, in particular, the following:
a) The processing of personal data in violation of the principles and guarantees established in Article 5 of Regulation (EU) 2016/679. (...)"

V

Proposal for sanction for the infringement of Article 5.1.f) GDPR

For the purpose of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available at this moment in the initiation agreement for sanctioning procedure, and without prejudice to the outcome of the investigation, it is considered appropriate to grade the sanction to be imposed according to the following criteria established in Article 83.2 of the GDPR:

As aggravating factors:

- The nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question, as well as the number of affected data subjects and the level of damage and harm suffered (paragraph a): due to the unauthorized access to particularly protected health data of at least 400 affected individuals, from December 21, 2021, to March 25, 2022, at a minimum.
- The categories of personal data affected by the infringement (paragraph g): In this case, according to the notification from the entity, data of racial origin, health, genetic data, among other personal data of the affected individuals, would have been exposed.

As mitigating factors:

- Any other aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or the losses avoided, directly or indirectly, through the infringement (paragraph k): a series of measures were adopted, such as (...), among others.

It is also considered appropriate to grade the sanction to be imposed according to the following criteria established in paragraph 2 of Article 76 "Sanctions and corrective measures" of the LOPDGDD:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

8/18

- The connection of the infringer's activity with the processing of personal data (section b): this is an entity accustomed to processing health-related personal data.

As mitigating factors:

- Having a data protection officer when it was not mandatory (section g).

The balance of the circumstances contemplated in Article 83.2 of the GDPR and Article 76.2 of the LOPDGDD, regarding the infringement committed by violating the provisions of Article 5.1.f) of the GDPR, initially allows for the imposition of a fine of €50,000 (fifty thousand euros).

VI

Security Measures

Article 32 "Security of Processing" of the GDPR states:

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;
- d) a process for regularly verifying, assessing, and evaluating the effectiveness of technical and organizational measures to ensure the security of processing.

2. In assessing the appropriateness of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data only processes such data on instructions from the controller, unless required to do so by Union or Member State law."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/18

In this case, at the time of the breach, there is reasonable and sufficient evidence that the security measures, both technical and organizational, that INSTITUTO MARQUÉS had in relation to the data it processed were not adequate.

Given that the company processes health data, race, among others, as these are specially protected data whose breach would imply a greater risk to the rights and freedoms of individuals, an additional risk is presumed that must be assessed and that increases the requirement for the level of protection concerning the security and safeguarding of the integrity and confidentiality of these data.

This risk must be taken into account by the data controller who, based on this, must establish the necessary technical and organizational measures to prevent the loss of control of the data by the data controller and, therefore, by the data subjects who provided them.

From the described facts, it is not evident that INSTITUTO MARQUÉS, as the data controller now analyzed, had the appropriate technical and organizational measures in place to ensure a level of security adequate to the risk, at least concerning the (...) of the company.

In accordance with the evidence available in this initiation agreement of the sanctioning procedure, and without prejudice to what results from the instruction, it is considered that the known facts could constitute an infringement attributable to INSTITUTO MARQUÉS for violating Article 32 of the GDPR.

VII

Classification and Qualification of the Infringement of Article 32 of the GDPR

If confirmed, the aforementioned infringement of Article 32 of the GDPR could constitute the commission of the infringements classified in Article 83.4 of the GDPR, which under the heading "General Conditions for the Imposition of Administrative Fines" states:

"Infringements of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to €10,000,000 or, in the case of an enterprise, an amount equivalent to 2% at most of the total annual global turnover of the preceding financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)" In this regard, the LOPDGDD, in its Article 71 "Infringements" establishes that "Acts and conduct referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those contrary to this organic law, constitute infringements."

For the purposes of the limitation period, Article 73 "Infringements Considered Serious" of the LOPDGDD indicates:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
10/18

"Based on the provisions of Article 83.4 of Regulation (EU) 2016/679, serious infringements that constitute a substantial violation of the articles mentioned therein shall be subject to a two-year limitation period, particularly the following:

(...)

f) The failure to adopt those technical and organizational measures that are appropriate to ensure a level of security adequate to the risk of processing, as required by Article 32.1 of Regulation (EU) 2016/679."

(...)

VIII

Proposal for sanction for the infringement of Article 32 of the GDPR

For the purpose of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available at this moment of the initiation of the sanctioning procedure, and without prejudice to the outcome of the instruction, it is considered appropriate to scale the sanction to be imposed according to the following criteria established by Article 83.2 of the GDPR:

As aggravating factors:

- The nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question as well as the number of affected individuals and the level of damage and harm suffered (paragraph a): for not having adequate security measures, which allowed the data of at least 400 individuals to be affected by a breach such as in the present case, which enabled the violation of the confidentiality of these health data from December 21, 2021, to March 25, 2022, and the unavailability of part of this data from December 21, 2021, to the present.
- The categories of personal data affected by the infringement (paragraph g): In this case, according to the notification from the entity, data of racial origin, health, genetic, among other personal data of the affected individuals, would have been compromised.

As mitigating factors:

- Any other aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or the losses avoided, directly or indirectly, through the infringement (paragraph k): the company had adopted a series of measures (although insufficient) to prevent a security breach from occurring and subsequently also adopted measures to improve its security systems such as (...), among others.

Furthermore, it is considered appropriate to scale the sanction to be imposed according to the following criteria established by paragraph 2 of Article 76 "Sanctions and corrective measures" of the LOPDGDD:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

11/18

- The link of the infringer's activity with the processing of personal data (paragraph b): it is an entity accustomed to processing personal health data.

As mitigating factors:

- Having, when not mandatory, a data protection officer (paragraph g):

The balance of the circumstances contemplated in Article 83.2 of the GDPR and Article 76.2 of the LOPDGDD, regarding the infringement committed by violating the provisions of Article 32 of the GDPR, allows for an initial sanction of €20,000 (twenty thousand euros).

IX

Communication of a data security breach

Article 34 "Communication of a personal data security breach to the data subject" of the GDPR establishes:

"1. When it is likely that a personal data security breach will result in a high risk to the rights and freedoms of natural persons, the data controller shall communicate it to the data subject without undue delay.

2. The communication to the data subject referred to in paragraph 1 of this article shall describe in clear and plain language the nature of the personal data security breach and shall contain at least the information and measures referred to in Article 33, paragraph 3, letters b), c), and d).

3. The communication to the data subject referred to in paragraph 1 shall not be necessary if any of the following conditions are met:

a) the data controller has implemented appropriate technical and organizational protection measures and those measures have been applied to the personal data affected by the personal data security breach, in particular those that render the personal data unintelligible to any person not authorized to access it, such as encryption;

b) the data controller has taken subsequent measures that ensure that the high risk to the rights and freedoms of the data subject referred to in paragraph 1 is no longer likely to materialize;

c) it would involve a disproportionate effort. In this case, a public communication or a similar measure shall be adopted to inform the data subjects in an equally effective manner.

4. When the data controller has not yet communicated the personal data security breach to the data subject, the supervisory authority, after considering the likelihood that such a breach will result in a high risk, may require the data controller to do so or may decide that any of the conditions mentioned in paragraph 3 are met."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

12/18

In the present case, the breach posed a high risk to the rights and freedoms of individuals. According to the statements made by INSTITUTO MARQUÉS, (...).

(...).

Regarding the communication to the affected individuals, Article 34.1 of the GDPR states that such communication must be made to the data subject without undue delay. In this regard, the present file does not indicate that communication was made to all affected individuals whose personal data was exposed, as the statements from INSTITUTO MARQUÉS refer to the fact that "the Deputy Director General of INSTITUTO MARQUÉS sent emails to all those email accounts of actual patients that were copied in those communications to inform them of what happened...". From this statement, it is clearly deduced that the communication was not sent to all individuals who may have seen their personal data exposed.

Furthermore, the communication did not occur "without undue delay" as established in Article 34, given that the attack was recorded on December 21, 2021, and possible communications did not begin until March 25, 2022, that is, three months after the record of the cyber attack, without justification for such delay.

On the other hand, Article 34.2 of the GDPR refers to Article 33 of the GDPR regarding the content that this communication must have. Thus, the content is that collected in Article 33, paragraph 3, letters b), c), and d) of the GDPR, which states:

"3. The notification referred to in paragraph 1 shall, at a minimum:

b) communicate the name and contact details of the data protection officer or another contact point

where more information can be obtained;

c) describe the possible consequences of the personal data breach;

d) describe the measures taken or proposed by the data controller to remedy the security breach, including, where appropriate, the measures taken to mitigate the possible negative effects.”

In this case, the content of the emails that INSTITUTO MARQUÉS has sent does not comply with the provisions of Article 33 of the GDPR to the extent that they have provided a copy of three of these sent emails in which it can be seen that they include (...), but do not include the requirements set forth in Article 33.3, paragraphs b), c), and d), and 34.2 of the GDPR.

In this case, the breach posed a high risk to the rights and freedoms of individuals, and none of the circumstances listed in paragraph 3 of Article 34 of the GDPR that would exempt INSTITUTO MARQUÉS from the duty to duly communicate to the affected individuals that this breach had occurred were present.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

13/18

In accordance with the evidence available in this initiation agreement for sanctioning procedure, and without prejudice to the outcome of the instruction, it is considered that the known facts could constitute an infringement attributable to INSTITUTO MARQUÉS for violation of Article 34 of the GDPR.

X

Classification and qualification of the infringement of Article 34 of the GDPR

If confirmed, the aforementioned infringement of Article 34 of the GDPR could imply the commission of the infringements classified in Article 83.4 of the GDPR, which under the heading “General conditions for the imposition of administrative fines” states:

“Violations of the following provisions shall be subject to administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to 2% of the total annual global turnover of the preceding financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)”

In this regard, the LOPDGDD, in its Article 71 “Infringements” establishes that “Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those contrary to this organic law, constitute infringements.”

For the purposes of the statute of limitations, Article 74 “Minor Infringements” of the LOPDGDD indicates:

“Minor infringements will be considered and will prescribe after one year for the remaining formal infringements of the articles mentioned in paragraphs 4 and 5 of Article 83 of Regulation (EU) 2016/679 and, in particular, the following:

“(...)”

ñ) The failure to communicate to the affected individual a breach of security of personal data that poses a high risk to the rights and freedoms of the affected individuals, in accordance with the requirements of Article 34 of Regulation (EU) 2016/679, unless the provisions of Article 73 s) of this organic law apply. (...)”

XI

Proposal for sanction for the infringement of Article 34 of the GDPR

For the purpose of deciding on the imposition of an administrative fine and its amount, in accordance with the evidence available at this moment in the initiation agreement for sanctioning procedure, and without prejudice to the outcome of the instruction, it is considered appropriate to grade the sanction to be imposed according to the following criteria established in Article 83.2 of the GDPR:

As aggravating factors:

C/ Jorge Juan, 6

www.aepd.es

- The nature, severity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question as well as the number of affected parties and the level of damages they have suffered (section a): For failing to inform at least 400 affected individuals that the security breach in question had occurred, and for not communicating all the information required by Article 34.2 of the GDPR, without undue delay (between December 21, 2021, and March 25, 2022), to the affected individuals who were indeed notified.
- The categories of personal data affected by the infringement (section g): In this case, according to the notification from the entity, data related to racial origin, health, genetics, among other personal data of the affected individuals, would have been compromised.

As mitigating factors:

- Any measures taken by the data controller or processor to mitigate the damages suffered by the affected individuals (section c): partial or incomplete information about the existence of the breach was provided to some affected individuals.

It is also considered appropriate to adjust the sanction to be imposed according to the following criteria established in section 2 of Article 76 “Sanctions and corrective measures” of the LOPDGDD:

- The connection of the infringer's activity with the processing of personal data (section b): it is an entity accustomed to processing health-related personal data.

As mitigating factors:

- Having, when not mandatory, a data protection officer (section g):

The balance of the circumstances contemplated in Article 83.2 of the GDPR and Article 76.2 of the LOPDGDD, regarding the infringement committed by violating the provisions of Article 34 of the GDPR, allows for an initial sanction of €10,000 (ten thousand euros).

XII

Imposition of measures

If the infringement is confirmed, it could be agreed to impose on the controller the adoption of appropriate measures to align its actions with the regulations mentioned in this act, without prejudice to what is established in the aforementioned Article 58.2 d) of the GDPR, according to which each supervisory authority may “order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, where appropriate, in a specific manner and within a specified timeframe...”. The imposition of this measure is compatible with the sanction consisting of an administrative fine, as provided in Article 83.2 of the GDPR.

Furthermore, the measures that may be adopted in the resolution that concludes the procedure would be applicable in all countries of the European Union where INSTITUTO MARQUÉS operates.

It is warned that failure to comply with the requirements of this body could be considered an administrative infringement in accordance with the provisions of the GDPR, classified as an infringement in its Articles 83.5 and 83.6, which could lead to the initiation of a further administrative sanctioning procedure.

Therefore, in light of the above, by the Director of the Spanish Agency for Data Protection,
IT IS AGREED:

FIRST: TO INITIATE SANCTIONING PROCEDURE against INSTITUT MARQUÉS OBSTETRICIA I GINECOLOGIA, S.L.P., with NIF B62187323,

- for the alleged infringement of Article 5.1.f) of the GDPR classified in Article 83.5 of the GDPR
- for the alleged infringement of Article 32 of the GDPR classified in Article 83.4 of the GDPR,
- for the alleged infringement of Article 34 of the GDPR classified in Article 83.4 of the GDPR

SECOND: TO APPOINT A.A.A. as the instructor and B.B.B. as the secretary, indicating that they may be challenged, if applicable, in accordance with the provisions of Articles 23 and 24 of Law 40/2015, of October 1, on the Legal Regime of the Public Sector (LRJSP).

THIRD: TO INCORPORATE into the sanctioning file, for evidentiary purposes, the documentation from the IMI that has led to the prior investigation actions, as well as the documents obtained and generated

by the General Subdirectorate of Data Inspection in the actions prior to the initiation of this sanctioning procedure and the documentation from the IMI regarding the draft decision.

FOURTH: THAT for the purposes provided in Article 64.2 b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, the sanction that may correspond would be:

- For the alleged infringement of Article 5.1.f) of the GDPR, classified in Article 83.5 of that regulation, an administrative fine of €50,000.00
- For the alleged infringement of Article 32 of the GDPR, classified in Article 83.4 of that regulation, an administrative fine of €20,000.00

16/18

- For the alleged violation of Article 34 of the GDPR, classified under Article 83.4 of said regulation, an administrative fine of 10,000.00 euros.

FIFTH: NOTIFY this agreement to INSTITUT MARQUÉS OBSTETRICIA I GINECOLOGIA, S.L.P., with NIF B62187323, granting a hearing period of ten working days for it to submit allegations and present any evidence it deems appropriate. In its allegations, it must provide its NIF and the procedure number indicated in the heading of this document. If no allegations are made within the stipulated period regarding this initiation agreement, it may be considered a proposal for resolution, as established in Article 64.2.f) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP).

In accordance with the provisions of Article 85 of the LPACAP, it may acknowledge its responsibility within the period granted for the formulation of allegations to this initiation agreement; this will entail a reduction of 20% of the fine that may be imposed in this procedure. With the application of this reduction, the fine would be established at 64,000.00 euros, resolving the procedure with the imposition of this fine.

Similarly, it may, at any time prior to the resolution of this procedure, make voluntary payment of the proposed fine, which will imply a reduction of 20% of its amount. With the application of this reduction, the fine would be established at 64,000.00 euros, and its payment will imply the termination of the procedure, without prejudice to the imposition of the corresponding measures.

The reduction for the voluntary payment of the fine is cumulative with the one corresponding to the acknowledgment of responsibility, provided that this acknowledgment of responsibility is made within the period granted for formulating allegations to the opening of the procedure. The voluntary payment of the amount referred to in the previous paragraph may be made at any time prior to the resolution. In this case, if both reductions were to apply, the amount of the fine would be established at 48,000.00 euros.

In any case, the effectiveness of either of the two mentioned reductions will be conditioned upon the withdrawal or waiver of any action or administrative appeal against the fine.

In the event that it opts to proceed with the voluntary payment of any of the amounts indicated above (64,000.00 euros or 48,000.00 euros), it must make the payment by depositing it into account No. IBAN: ES00-0000-0000-0000-0000 opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A., indicating in the concept the reference number of the procedure that appears in the heading of this document and the reason for the reduction of the amount to which it is entitled.

Furthermore, it must send the proof of payment to the General Subdirectorate of Inspection to continue with the procedure in accordance with the amount deposited.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

17/18

The procedure will have a maximum duration of twelve months from the date of the initiation agreement. After this period, it will expire, and consequently, the file will be archived; in accordance with the provisions of Article 64 of the LOPDGDD.

Finally, it is noted that according to the provisions of Article 112.1 of the LPACAP, there is no administrative appeal against this act.

935-030423

Mar España Martí

Director of the Spanish Agency for Data Protection

>>

SECOND: On October 18, 2023, the respondent has proceeded to pay the fine in the amount of 48,000 euros, utilizing both reductions provided for in the previously transcribed Initiation Agreement, which implies the acknowledgment of responsibility.

THIRD: The payment made, within the period granted for formulating allegations to the opening of the procedure, entails the waiver of any action or administrative appeal against the fine and the acknowledgment of responsibility concerning the facts referred to in the Initiation Agreement.

LEGAL GROUNDS

I

Competence

In accordance with the powers granted by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), to each supervisory authority and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and the guarantee of digital rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection will be governed by the provisions of Regulation (EU) 2016/679, this organic law, the regulatory provisions issued in its development, and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Termination of the procedure

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

18/18

Article 85 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), under the heading "Termination in sanctioning procedures" provides as follows:

"1. Once a sanctioning procedure has been initiated, if the offender acknowledges their responsibility, the procedure may be resolved with the imposition of the appropriate sanction.

2. When the sanction is solely of a pecuniary nature or when a pecuniary sanction can be imposed alongside a non-pecuniary sanction but the latter has been justified as inappropriate, voluntary payment by the presumed responsible party, at any time prior to the resolution, will imply the termination of the procedure, except with regard to the restoration of the altered situation or the determination of compensation for the damages caused by the commission of the infringement.

3. In both cases, when the sanction is solely of a pecuniary nature, the competent authority to resolve the procedure shall apply reductions of at least 20% on the amount of the proposed sanction, which shall be cumulative. The aforementioned reductions must be specified in the notification of the initiation of the procedure and their effectiveness shall be conditioned upon the withdrawal or renunciation of any action or administrative appeal against the sanction. The percentage of reduction provided for in this section may be increased by regulation."

In accordance with the above,

the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO DECLARE the termination of procedure EXP202204816, in accordance with the provisions of Article 85 of the LPACAP.

SECOND: TO NOTIFY this resolution to INSTITUT MARQUÉS OBSTETRICIA I GINECOLOGIA, S.L.P.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure as prescribed by Article 114.1.c) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, the interested parties may file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating Contentious-Administrative Jurisdiction, within a period of two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

936-040822

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es